

Organização e escopo do SGSI:

Versão do Anexo A considerada: ISO/IEC 27001:2022

Aprovado por:

Data:

Próxima revisão:

Controle do Anexo A	Aplicável	Justificativa	Status	Evidência
A.5.15 Controle de acesso	Sim	Sistemas em escopo tratam dado pessoal e exigem restrição por perfil; também cobrado pelo art. 46 da LGPD e pelo critério CC6.2 do SOC 2	Implementado	Política aprovada em 12/03, matriz de perfis, relatório da revisão trimestral
A.8.13 Cópias de segurança	Sim	Disponibilidade dos serviços em escopo; sustenta o RTO do plano de continuidade	Parcialmente implementado	Norma vigente, registro diário de execução, relatório do teste de restauração semestral; pendentes dois sistemas novos
A.5.24 Preparação da resposta a incidentes	Sim	Necessário ao dever de comunicação do art. 48 da LGPD e ao prazo contratual de notificação a clientes	Implementado	Plano aprovado, matriz de acionamento, relatório do exercício anual
A.8.30 Desenvolvimento terceirizado	Não	Não se terceiriza desenvolvimento; toda codificação em escopo é de equipe própria. Reavaliar se houver fábrica de software	Não aplicável	Declaração do diretor de tecnologia, revista na análise crítica anual

A amarração que o auditor rastreia: a cláusula 6.1.3 exige que os controles decorram da comparação com o tratamento de risco. A justificativa boa cita a obrigação externa E o risco interno; à pergunta "qual risco este controle trata?", a SoA precisa ter resposta.

O erro mais comum: SoA sem status de implementação e sem apontar a evidência. Vira lista de intenções: diz que o controle é aplicável e não diz se ele existe nem onde está a prova. O auditor descobre na primeira hora, e a conversa deixa de ser sobre o sistema de gestão e passa a ser sobre a credibilidade do documento.